

System & Communications Protection (SC) — CMMC Level 1

SC.L1-b.1.xi (NIST 3.13.5) · Control Readiness Sheet

0. Control Identity

Practice	“Implement subnetworks for publicly accessible system components that are physically or logically separated from internal networks.”
Level / Protects	Level 1 · FCI (Federal Contract Information), not CUI
Source	FAR 52.204-21(b)(1)(xi) · NIST SP 800-171 3.13.5 · CMMC L1 Assessment Guide v2.13
Objectives	[a] publicly accessible system components are identified; [b] subnetworks for publicly accessible components are implemented; [c] those subnetworks are physically or logically separated from internal networks.

1. Intent

Public-facing components — a web server, a public portal, an email gateway — are exposed to the internet and more likely to be attacked. They belong in a separated zone (a DMZ) so that if one is compromised, the attacker cannot pivot straight into the internal network where FCI lives. The control is about segmentation: keeping the risky, public-facing things away from the trusted, internal things.

Note the control has no FCI qualifier on the component itself. A public-facing server that holds no FCI still falls in scope, because the risk being controlled is lateral movement into the internal network — not the exposure of the public component.

2. Ownership

Responsible	Network / System Administrator — designs and maintains the network segmentation.
Accountable	IT Manager / Head of IT — owns the architecture decision and the outcome.

Tailor per client — titles flex; every control has one named, accountable owner.

3. Assessment — how an assessor audits it

- Examine: network diagram showing the DMZ/segmentation; firewall rules between the public segment and the internal network; subnet inventory.
- Interview: network/IT staff on how publicly accessible components are identified and isolated from internal systems.
- Test: confirm the public segment is actually separated — verify traffic from the DMZ cannot reach internal systems except through controlled paths (obj. c).

4. Evidence to Have Ready

Network diagram identifying public-facing components and the DMZ; firewall/segmentation rules; description of physical or logical separation.

If the control is declared Not Applicable: the evidence changes category. It no longer proves implementation — it proves the condition. Expect to produce a subnet inventory, an external attack-surface or port scan showing no inbound reachability, the boundary definition itself, and documentation that public-facing services are hosted outside the boundary.

5. Customer Questions

- Do you have any public-facing systems — a website, web app, email server, portal, API, or VPN concentrator — that you host or operate yourself?
- If yes, are those separated from your internal network (a DMZ or equivalent), or do they sit on the same flat network?
- Can you show that separation on a network diagram, and show me the subnet inventory it is based on?
- For anything you call cloud-hosted — who operates it, you or the provider?

6. Not Applicable — Determination

Eligibility: MOST COMMON N/A CANDIDATE at Level 1. Genuinely Not Applicable when no system components within the assessment boundary are accessible from public networks — for example, a small firm whose website and email are fully SaaS-hosted by a third party outside the boundary. This is the one Level 1 control where N/A is frequently legitimate. It is still a determination to be proven, not an assumption.

A defensible N/A has three written parts:

- The determination — stated in the control's own vocabulary. The requirement says “components,” so the determination must say components. Narrowing it to “no public web servers” quietly excludes API gateways, status pages, VPN concentrators, and self-hosted tooling, and an assessor will hold you to the wider word.
- The boundary logic — the evidence that the condition holds: what defines the boundary, what is inside it, and how you know nothing inside it is publicly reachable.
- The re-evaluation trigger — the event that voids the determination. Without it, a legitimately inapplicable control becomes silently unmet the day someone stands up a public service.

Model verbiage: “SC.L1-b.1.xi is Not Applicable. No system components within the defined assessment boundary are accessible from public networks. All FCI-processing components reside on internal networks with no inbound reachability from the internet, as evidenced by [network diagram / subnet inventory / external scan] dated _____. Publicly accessible services used by the organization are hosted by third-party providers outside the assessment boundary, and no FCI transits or resides on them. With no publicly accessible components inside the boundary, there is nothing to separate and the practice has no applicable implementation. This determination is void and the control must be re-assessed if any publicly accessible component is introduced into the boundary.”

Common pitfall: Assuming cloud puts the component out of scope. Cloud does not remove the boundary — it relocates it. If the organization operates the public-facing service, it is in scope wherever it runs; if a third party operates it, that must be established, not assumed.

7. Commercial Framework Mapping

Framework	Primary	Supporting	Called
SOC 2 (TSC)	CC6.1 — logical access architecture; its points of focus expressly address network segmentation	CC6.6 — protects against threats from sources outside the system boundary	Network segmentation
ISO 27001:2022	A.8.22 Segregation of networks	A.8.20 Networks security	Network segregation

Primary = the criterion this control most directly satisfies. **Supporting** = criteria it contributes evidence toward and an auditor will also want to see.

What changes commercially: CMMC asks whether the separation exists. SOC 2 judges design adequacy — is the segmentation actually effective — and expects the firewall rules enforcing it to be evidenced and reviewed across the whole review period. ISO expects it to sit inside a managed network-security process, not to be a one-time architecture decision.

Access Control (AC) — CMMC Level 1

AC.L1-b.1.iv (NIST 3.1.22) · Control Readiness Sheet

0. Control Identity

Practice	“Control information posted or processed on publicly accessible information systems.”
Level / Protects	Level 1 · FCI (Federal Contract Information), not CUI
Source	FAR 52.204-21(b)(1)(iv) · NIST SP 800-171 3.1.22 · CMMC L1 Assessment Guide v2.13
Objectives	[a] individuals authorized to post or process information on publicly accessible systems are identified; [b] procedures to ensure FCI is not posted or processed on publicly accessible systems are identified; [c] a review process is in place prior to posting of any content to publicly accessible systems; [d] content on publicly accessible systems is reviewed to ensure it does not include FCI; [e] mechanisms are in place to remove and address improper posting of FCI.

1. Intent

Public systems — your website, social media, a public portal — are visible to anyone. This control makes sure FCI never gets posted to them, whether by accident or by an unauthorized person. The mechanism is a review step: someone authorized checks content before it goes public, so contract information doesn't leak into the open.

Objective [e] is the one most often missed. The control does not stop at prevention — it requires a mechanism to remove FCI and address the incident once something improper has already been posted.

2. Ownership

Responsible	IT Administrator + Web/Marketing content owner — whoever publishes to public systems and whoever reviews.
Accountable	IT Manager / Head of IT (or Communications lead) — owns the review process and the outcome.

Tailor per client — titles flex; every control has one named, accountable owner.

3. Assessment — how an assessor audits it

- Examine: list of publicly accessible systems; content-review/approval procedure; records of who is authorized to post; takedown/removal procedure (obj. e).
- Interview: staff who post public content on who reviews it, how FCI is kept off public systems, and what happens when something improper is discovered.
- Test: review current public sites/pages for any FCI exposure; confirm the review step actually occurs before posting; confirm a removal mechanism exists and is exercisable.

4. Evidence to Have Ready

List of publicly accessible systems; content-review and approval procedure; list of authorized publishers; documented removal/remediation procedure for improper postings.

5. Customer Questions

- Do you have a public website, portal, or social media that your organization posts to?
- Who is allowed to post, and does anyone review content before it goes public?
- How do you make sure contract information never ends up on a public page?
- If FCI did get posted by mistake, what is the process to take it down and address it?

6. Not Applicable — Determination

Eligibility: CONDITIONAL. N/A only if the organization maintains no publicly accessible information systems at all within the assessment boundary on which information could be posted or processed. This is uncommon —

most organizations have at least a website — so confirm carefully before declaring N/A. If a third party fully hosts and controls the public site and the organization never posts to any public system, a scoped N/A may be defensible.

Model verbiage: “AC.L1-b.1.iv is Not Applicable. [Organization] maintains no publicly accessible information systems within the assessment boundary on which information could be posted or processed, as evidenced by [artifact]. Public-facing presence is hosted and controlled entirely by a third party outside the boundary, and no personnel of [Organization] post or process information on it. With no public system under the organization's control, the practice has no applicable implementation. This determination is void and the control must be re-assessed if a publicly accessible system is introduced or if personnel begin posting to a third-party public system on the organization's behalf.”

Common pitfall: Treating a third-party-hosted website as automatically out of scope. If your staff publish to it, the posting activity is yours even when the infrastructure is not.

7. Commercial Framework Mapping

Framework	Primary	Supporting	Called
SOC 2 (TSC)	CC6.6 — protects against threats from sources outside the system boundary	CC6.7 — restricts transmission, movement and removal of information	Data exposure control
ISO 27001:2022	A.5.14 Information transfer	A.8.23 Web filtering	Information transfer

Primary = the criterion this control most directly satisfies. **Supporting** = criteria it contributes evidence toward and an auditor will also want to see.

What changes commercially: Commercially this widens into data-loss-prevention and public-disclosure controls. A SOC 2 auditor looks for a documented content-review and approval workflow that operated across the review period — not merely that a review policy exists today.